ANEXO 05

POLÍTICAS DE ACCESO Y SEGURIDAD

Plataforma de Gestión de Información de Privacidad (PIMS) — GESTITEL E.I.R.L.

Documentación técnica de base de datos — Documento 05

Versión del sistema documentada: migraciones core/0001 – core/0043 · customer/0001 – customer/0004

Arequipa, Perú — Octubre 2026

TABLA DE CONTENIDO

A quién va dirigido 4
Qué contiene 4
0. Los siete controles, en orden 4
1. Aislamiento por empresa — el control más fuerte del sistema 4
1.1 Cómo funciona 4
1.2 Por qué es más robusto que filtrar por columna 5
1.3 Protección adicional en el token de sesión 5
2. Autenticación 5
2.1 Alta de usuarios 6
2.2 Superadministradores de Gestitel y el mecanismo de usuario espejo 6
3. Vigencia de la licencia 6
3.1 Excepciones al bloqueo, y por qué existen 7
3.2 Límite de documentos por empresa — un control análogo, administrado por el superadministrador 7
3.3 Configuración del asistente de consultas teóricas — otro control exclusivo del superadministrador 7
4. Autorización: quién puede ver, modificar o borrar 8
4.1 El modelo 8
4.2 Regla nº 1: leer también requiere permiso 8
4.3 Regla nº 2: ningún punto de entrada queda abierto por descuido 9
4.4 Regla nº 3: las acciones especiales no usan el permiso que parecería 9
4.5 Los 16 módulos y su permiso 9
4.6 Dos permisos con lógica propia 10
4.7 Los tres roles predefinidos 11
4.8 La única superficie sin autenticación: el formulario público ARCO-P 11
5. Protección de archivos: ningún archivo es público 12
5.1 Registro de permisos por tipo de archivo 12
5.2 Cuatro medidas adicionales 12
6. Trazabilidad: la bitácora inmutable 13
6.1 Qué se registra 13
6.2 Inmutabilidad 13
6.3 La bitácora nunca rompe la operación 13
6.4 La bitácora no contiene datos personales 14
6.5 Bitácora de plataforma 14
7. Tratamiento de datos personales (ISO/IEC 27701 y Ley N.º 29733) 14
7.1 Dónde hay datos personales 14
7.2 Las cinco medidas aplicadas 15
7.3 Derechos de los titulares 15
7.4 Localización de los datos 15
8. Seguridad del transporte y de la configuración 16

8.1 La aplicación web: qué controla y qué no....16
9. Limitaciones conocidas y supuestos....17
Resumen ejecutivo....18
Documentos relacionados....18

A quién va dirigido

A responsables de seguridad de la información, oficiales de protección de datos, auditores internos y externos de ISO/IEC 27001 e ISO/IEC 27701, y personal técnico que deba operar o integrar la plataforma.

Qué contiene

Responde a la pregunta **quién puede ver, modificar o borrar cada dato**, describiendo los siete controles que lo determinan, en el orden en que actúan sobre cada petición:

1. Aislamiento por empresa.
2. Autenticación.
3. Vigencia de la licencia.
4. Autorización por permisos de módulo.
5. Protección de archivos.
6. Trazabilidad: la bitácora inmutable.
7. Tratamiento de datos personales (ISO/IEC 27701 y Ley N.º 29733).

Al final se recogen las **limitaciones conocidas y los supuestos**, que un auditor debe conocer para valorar el alcance real de cada control.

0. Los siete controles, en orden

Toda petición al sistema atraviesa esta secuencia. **Si cualquiera de los pasos falla, la petición se rechaza y no llega al dato.**

```
Petición
   │
   ├─ 1. ¿A qué empresa corresponde el dominio?          → se fija el esquema PostgreSQL
   │                                                       (sin esquema válido, no hay datos)
   ├─ 2. ¿Quién es el usuario?                           → token JWT válido y del esquema correcto
   │                                                       (si no: 401 No autenticado)
   ├─ 3. ¿La empresa tiene licencia vigente?             → (si no: 403 con código explicativo)
   │
   ├─ 4. ¿Tiene permiso sobre este módulo y esta acción? → (si no: 403 Prohibido)
   │
   ├─ 5. Si pide un archivo: ¿de su empresa? ¿con permiso sobre ese tipo de archivo?
   │
   ├─ 6. Se ejecuta la operación y SE REGISTRA en la bitácora inmutable
   │
   └─ 7. Si el dato es personal: reglas adicionales de minimización y trazabilidad
```

1. Aislamiento por empresa — el control más fuerte del sistema

1.1 Cómo funciona

Los datos de cada empresa viven en **un esquema PostgreSQL propio**. Antes de ejecutar cualquier consulta, el sistema resuelve —a partir del dominio por el que entró la petición— **en qué esquema debe situarse la conexión**. A partir de ahí, toda consulta se ejecuta dentro de ese esquema y **no puede alcanzar los datos de otra empresa**.

```
https://empresa-a.27k.pe/...  →  customer_domain  →  customer_client.schema_name = 'empresa_a'
                                                   →  SET search_path TO empresa_a
                                                   →  todas las consultas van a empresa_a
```

1.2 Por qué es más robusto que filtrar por columna

La alternativa habitual es una única base de datos con una columna `empresa_id` en cada tabla y un filtro en cada consulta. Ese diseño falla en cuanto **una sola consulta olvida el filtro**: devuelve datos de todas las empresas, en silencio, sin error.

Con el aislamiento por esquema **ese error no es posible**: no hay filtro que olvidar. Una consulta mal escrita, en el peor caso, devuelve datos incorrectos **de la propia empresa**.

Se refuerza además con dos medidas:

- **No existe ninguna llave foránea entre esquemas.** Ni desde el control de plataforma hacia una empresa ni entre empresas. No hay camino físico para cruzar datos.
- **Cada empresa tiene sus propias tablas de usuarios, roles y permisos** (`auth_user`, `auth_group`, `auth_permission`). Un usuario de la empresa A **no existe** en la empresa B.

1.3 Protección adicional en el token de sesión

Aun teniendo esquemas separados, un token de sesión obtenido en una empresa no debe servir en otra. Por eso **el token lleva grabado el esquema para el que se emitió**, y la capa de autenticación lo compara con el esquema de la petición en curso:

```
# core/authentication.py
class TenantJWTAuthentication(JWTAuthentication):
    """Valida que el claim `schema` del token coincida con el esquema del
    tenant actual. Si no coincide, rechaza con 401."""

    def get_validated_token(self, raw_token):
        validated = super().get_validated_token(raw_token)
        if validated.get('schema') != getattr(connection, 'schema_name', None):
            raise InvalidToken("El token no corresponde a esta empresa.")
        return validated
```

Un token sin ese dato (por ejemplo, uno antiguo) **se rechaza igualmente**.

2. Autenticación

Aspecto	Implementación
Mecanismo	Tokens **JWT** (`djangorestframework-simplejwt`).
Vigencia del token de acceso	**8 horas**.
Vigencia del token de renovación	**1 día**.
Almacenamiento de contraseñas	Resumen criptográfico con sal, mediante el mecanismo estándar de Django. **Las contraseñas nunca se almacenan ni se transmiten en claro, y no son recuperables.**
Límite de intentos de inicio de sesión	**5 por minuto** por origen.

Aspecto	Implementación
Política de contraseña	Cinco validadores activos: longitud mínima (8), no similar a los datos del usuario, no figurar entre las contraseñas comunes conocidas, no ser enteramente numérica y **combinar al menos una mayúscula, una minúscula, un número y un símbolo**. Se aplican al dar de alta o editar usuarios, al cambiar la propia contraseña y a las contraseñas que el superadministrador fija desde el panel de plataforma. La regla se aplica cada vez que se fija una contraseña.
Cambio forzado	`core_userprofile.must_change_password` obliga a cambiar la contraseña en el siguiente acceso. Se activa en toda alta de usuario.

2.1 Alta de usuarios

- La contraseña inicial **la escribe el administrador** al dar de alta al usuario; no se autogenera. Mínimo 8 caracteres, validada con las cinco reglas anteriores.
- El usuario queda obligado a cambiarla en su primer acceso.
- **El rol es obligatorio** en el alta, y **cada usuario tiene exactamente un rol**.

2.2 Superadministradores de Gestitel y el mecanismo de usuario espejo

Los implementadores de Gestitel necesitan acceder a cualquier empresa para dar soporte. Esto se resuelve **sin duplicar contraseñas** y de forma trazable:

- El superadministrador existe **una sola vez**, en `auth_user` del esquema `public`. Su contraseña se valida **siempre contra `public`**.
- Al acceder a una empresa, el sistema crea o recupera en el esquema de esa empresa un **usuario espejo** con el mismo nombre de usuario.
- Ese espejo **nunca tiene contraseña propia**:

```
# core/services/auth_service.py
if created:
    user.set_unusable_password()          # el espejo no puede autenticarse por sí mismo
    ...
if user.has_usable_password():
    user.set_unusable_password()          # y si alguna vez la tuviera, se le quita
```

- El espejo es superusuario **dentro de esa empresa**, y su perfil queda marcado con `is_platform_admin = true`, lo que hace que **no aparezca en el listado de usuarios** de la empresa.
- Cada acceso de un superadministrador a una empresa **queda registrado** en `customer_platformlog` con la acción `tenant_login`.

Implicación para un auditor: el personal de Gestitel puede acceder a los datos de cualquier empresa cliente. Es una capacidad inherente al modelo de servicio administrado, está **registrada** en la bitácora de plataforma, y debe reflejarse en el contrato de encargo de tratamiento entre Gestitel y la empresa.

3. Vigencia de la licencia

Cada empresa tiene licencias por días (`customer_license`). Un componente intermedio evalúa, **en cada petición**, si la empresa puede operar:

Situación	Código devuelto	Mensaje al usuario
Sin licencia, o fecha de fin superada, o estado «Vencida»	`LICENSE_EXPIRED`	«Su licencia ha vencido. Contacte a GESTITEL.»
Licencia suspendida, o empresa desactivada manualmente	`SERVICE_SUSPENDED`	«Suspensión del servicio, comunicarse con el administrador de la empresa GESTITEL»

Ambos devuelven **403**. Son dos situaciones distintas a propósito: una es comercial, la otra es una decisión administrativa.

3.1 Excepciones al bloqueo, y por qué existen

```
EXEMPT_PREFIXES = (
    '/business/login/',      # debe poder cargar para mostrar la pantalla de bloqueo
    '/business/info/',
    '/business/arcop/',      # formulario público de derechos ARCO-P
    '/static/', '/media/', '/assets/',
)
```

La excepción relevante es `/business/arcop/`. Una empresa con la licencia vencida **sigue recibiendo solicitudes de derechos de los ciudadanos**, porque atenderlas es una **obligación legal** que no depende de su relación comercial con Gestitel. Sus usuarios internos, en cambio, **siguen bloqueados**: pueden entrar solicitudes, pero nadie de la empresa puede consultarlas hasta regularizar la licencia.

Los superadministradores de Gestitel **nunca se bloquean**: deben poder entrar a regularizar la situación.

3.2 Límite de documentos por empresa — un control análogo, administrado por el superadministrador

Cada empresa puede tener además un **tope de archivos** en Gestión Documental (`customer_client.document_limit`), configurado **exclusivamente** por el superadministrador de Gestitel desde su panel — **no** forma parte del sistema de permisos por rol de la empresa, y ningún usuario de la empresa, por alto que sea su rol, puede cambiarlo. `NULL` significa sin límite. Al alcanzarlo, subir un archivo más devuelve **403** con un código de máquina (`DOCUMENT_LIMIT_REACHED`), con el mismo criterio de bloqueo explícito que la licencia — pero es un control **independiente**: una empresa puede tener la licencia vigente y el límite de documentos agotado al mismo tiempo, y viceversa. El superadministrador nunca se bloquea por este límite.

3.3 Configuración del asistente de consultas teóricas — otro control exclusivo del superadministrador

El asistente de consultas teóricas (apartado 7.4) se gobierna desde una única pantalla del panel del superadministrador de Gestitel, respaldada por la tabla de fila única `customer_platformaisettings` del esquema `public`:

- **Quién puede cambiarla:** solo un superadministrador de Gestitel. **No forma parte del sistema de permisos por rol de la empresa**: ningún usuario de una empresa cliente, por alto que sea su rol, puede ver ni modificar el interruptor, el modelo o la clave. Es una sola configuración para toda la plataforma; no existe una por empresa.

- **Qué controla:** si el asistente está encendido, qué proveedor y qué modelo responden, y la clave de acceso a ese proveedor.
- **Triple condición de encendido.** El asistente solo aparece y responde si se cumplen a la vez tres cosas: el interruptor está encendido, hay una clave guardada, y el servidor dispone de la clave maestra de cifrado. Si falta cualquiera, la funcionalidad no se muestra a ningún usuario y su punto de entrada devuelve un error controlado. **Nace apagado.**
- **La clave no se puede leer de vuelta.** El panel nunca muestra la clave guardada: solo permite reemplazarla. Dejar el campo vacío conserva la existente.
- **Probar no guarda.** La pantalla ofrece una prueba de conexión con el proveedor que **no persiste ningún cambio**; guardar es siempre una acción aparte y explícita.
- **Queda registrado** en la bitácora de plataforma (apartado 6.5).

4. Autorización: quién puede ver, modificar o borrar

4.1 El modelo

Se apoya en el mecanismo nativo de permisos de Django. Por cada entidad de negocio existen cuatro permisos:

Permiso	Habilita
`view_<entidad>`	**Ver** (listar, consultar, exportar).
`add_<entidad>`	**Crear**.
`change_<entidad>`	**Modificar**.
`delete_<entidad>`	**Eliminar** (borrado lógico).

Los permisos **se asignan a roles**, no a usuarios. Cada usuario tiene un rol.

4.2 Regla nº 1: leer también requiere permiso

Por omisión, el marco de trabajo deja las peticiones de lectura abiertas a cualquier usuario autenticado. **En Gestitel esa omisión se corrige explícitamente**: `view_<entidad>` es obligatorio incluso para consultar.

```
# core/permissions/model_permissions.py
class ModulePermission(DjangoModelPermissions):
    perms_map = {
        "GET":    ["%(app_label)s.view_%(model_name)s"],   # ← exige view en lectura
        "POST":   ["%(app_label)s.add_%(model_name)s"],
        "PUT":    ["%(app_label)s.change_%(model_name)s"],
        "PATCH":  ["%(app_label)s.change_%(model_name)s"],
        "DELETE": ["%(app_label)s.delete_%(model_name)s"],
    }
```

Un usuario sin `view_incident` **no puede consultar ni un solo incidente**, ni por la interfaz ni llamando directamente a la API.

4.3 Regla nº 2: ningún punto de entrada queda abierto por descuido

La configuración global exige autenticación **en todo endpoint**, de modo que olvidar declarar el permiso de un endpoint nuevo produce, como mínimo, que exija estar autenticado —nunca que quede abierto—:

```
REST_FRAMEWORK = {
    'DEFAULT_PERMISSION_CLASSES': ('rest_framework.permissions.IsAuthenticated',),
}
```

El acceso sin autenticación debe declararse **explícitamente**, y hoy solo hay tres casos: el inicio de sesión, la consulta del nombre de la empresa en la pantalla de acceso, y el formulario público de derechos ARCO-P (apartado 4.8).

4.4 Regla nº 3: las acciones especiales no usan el permiso que parecería

Varias operaciones se realizan con el verbo HTTP `POST`, que por omisión se asociaría al permiso de **crear**. Eso sería incorrecto: no crean nada, **modifican** un registro existente. El sistema las reasigna una por una:

Acción	Permiso exigido	Razonamiento
`approve` (aprobar documento)	`approve_document`	Permiso propio: aprobar es un acto formal distinto de editar.
`revoke` (revocar consentimiento)	`change_consent`	Modifica el consentimiento.
`notify` (notificar incidente)	`change_incident`	Es una acción sobre el incidente.
`versions` (subir versión)	`change_document` en `POST`, `view_document` en `GET`	Subir una versión modifica el documento.
`attachments` (adjuntos)	`change_*` al subir o eliminar, `view_*` al listar	Adjuntar modifica el registro padre.
`actions` (registrar acción en ARCO-P)	`change_arcorequest`	Modifica el caso.
`assets` / `asset_detail` (líneas de un riesgo)	`change_riskevaluation` al escribir	**Quitar una línea no es borrar el riesgo**, es modificarlo.

4.5 Los 16 módulos y su permiso

La interfaz agrupa los permisos por módulo visible. El mapa completo:

Módulo	Permisos que agrupa
Documentos	`view/add/change/delete_document` + **`approve_document`**
Procesos	`view/add/change/delete_process`
Matriz de brecha	`view/add/change/delete_gaprequirement`
Metodología	`view/add/change/delete_evaluationmatrix` **y** `..._appraisalrange`
Inventario de activos	`view/add/change/delete_asset`
Riesgos (DPIIA)	`view/add/change/delete_riskevaluation`
EIPD (Datos Personales)	`view/add/change/delete_personaldataimpactassessment` — **permiso separado e independiente** del de Riesgos, aunque la pantalla vive como pestaña dentro de ese módulo: un usuario con acceso a Riesgos no ve automáticamente destinatarios, motivos ni descripciones de las operaciones sobre datos personales. Solo el rol Administrador lo trae por defecto.
Consentimientos	`view/add/change/delete_consent`

Módulo	Permisos que agrupa
Auditorías	`view/add/change/delete_audit`
Incidentes	`view/add/change/delete_incident`
Solicitudes ARCO-P	`view/add/change/delete_arcorequest`
Capacitaciones	`view/add/change/delete_training`
Capacitaciones (Ponente)	`can_manage_trainings`
Configuración del Sistema	`view/add/change/delete_systemcatalog`
Usuarios y Roles	`manage_users`
Seguridad	`view_securitylog` *(solo ver: la bitácora es inmutable)*

Entidades que no tienen permiso propio

Varias entidades **se gobiernan con el permiso de otra**, deliberadamente, para no multiplicar permisos que el administrador tendría que entender y mantener:

Entidad	Se gobierna con
Ítems de catálogo (`core_systemcatalogitem`)	Permisos de Configuración del Sistema.
Periodos de riesgo (`core_riskperiod`)	Permisos de Configuración del Sistema.
Declaración de Aplicabilidad (`core_gapannexaassessment`)	Permisos de Matriz de Brecha: **un solo permiso gobierna las dos pestañas**.
Destinatarios de notificación (`core_incidentrecipient`)	Permisos de Incidentes.
Todas las entidades hijas anidadas	Permiso de su entidad cabecera.

El Dashboard Ejecutivo no tiene permiso propio, ni de pestaña

La pantalla de inicio (Dashboard Ejecutivo) **no crea ningún permiso nuevo**. Cada uno de sus 20 indicadores exige el permiso del módulo cuyos datos usa; si un indicador cruza datos de dos módulos, exige el permiso de **ambos**, salvo que la población ya sea enumerable desde el módulo que el usuario sí tiene. Un indicador sin permiso **no llega a calcularse ni a viajar en la respuesta** — ni oculto, ni vacío: directamente no está. Una pestaña entera queda fuera del menú si ninguno de sus indicadores es visible para el usuario. Un usuario sin ningún indicador visible en absoluto recibe la pantalla de inicio igual, vacía, nunca un error de permiso: un «403» en la pantalla con la que arranca la sesión se vería como una aplicación rota.

4.6 Dos permisos con lógica propia

`manage_users` — gobierna la administración de usuarios y roles, que no sigue el patrón habitual porque `auth_user` y `auth_group` son tablas del marco de trabajo. Acceden los superusuarios o quien tenga este permiso.

`can_manage_trainings` — separa **dos vistas del mismo módulo**:

- **Vista de ponente**: crear capacitaciones, redactar el examen, asignar participantes, descargar certificados. Exige `can_manage_trainings`.
- **Vista de participante**: ver sus capacitaciones, rendir el examen, descargar su certificado. Exige solo `view_training`.

> **Detalle de seguridad relevante.** Las operaciones estándar de listado y consulta de capacitaciones son **exclusivas del ponente**, y no por comodidad: el formato de datos del ponente **incluye qué opción de cada pregunta es la correcta**. Un participante con `view_training` que llegara a ese formato vería las respuestas del examen. El participante usa **exclusivamente** los puntos de entrada `my/*`, que sirven el examen **sin** las respuestas correctas.

4.7 Los tres roles predefinidos

Toda empresa nace con estos tres roles:

Rol	Alcance
Administrador	Acceso completo a los 15 módulos, incluida la bitácora de seguridad y la vista de ponente de Capacitaciones. **Marcado como rol de sistema:** no se puede eliminar ni renombrar.
Editor *(«Oficial de protección de datos»)*	Ver, crear y editar en Documentos, Riesgos, Consentimientos, Solicitudes ARCO-P y Configuración del Sistema; solo ver en Capacitaciones. **Sin permiso de eliminar en ningún módulo.**
Lector	Solo ver, en doce módulos. Sin crear, editar ni eliminar en ninguno. **Sin acceso a la bitácora de seguridad ni a Usuarios y Roles.**

Los tres son **plantillas de partida**. Cada empresa puede crear roles propios y ajustar los permisos de cualquier rol desde la matriz de permisos de la pantalla de Usuarios y Roles.

> **Dos observaciones para el auditor.** (a) De los tres, **solo «Administrador» está marcado como rol de sistema**; «Editor» y «Lector» pueden renombrarse o eliminarse desde la interfaz. (b) La actualización de roles al instalar una versión nueva es **aditiva**: concede permisos nuevos pero **no revoca** los ajustes hechos manualmente en cada empresa.

4.8 La única superficie sin autenticación: el formulario público ARCO-P

Es el único punto del sistema accesible sin iniciar sesión, y existe por una razón legal: un ciudadano debe poder ejercer sus derechos sobre sus datos personales sin ser usuario de la plataforma.

```
# core/views/arcop_public_view.py
class ArcoPublicSubmitView(APIView):
    authentication_classes = []
    permission_classes     = [AllowAny]
    throttle_scope         = 'arcop_public'      # 10 peticiones por minuto
```

Las cinco restricciones que lo acotan:

1. **Solo crea. Nunca lista ni consulta.** No existe forma de leer solicitudes de terceros desde la superficie pública.
2. **El titular no puede fijar campos internos.** El formato aceptado expone únicamente los campos del solicitante, del representante y del derecho ejercido. El estado, la prioridad, el responsable y el plazo los fija el sistema.
3. **Límite de 10 peticiones por minuto** por origen.
4. **Máximo 5 archivos adjuntos** por envío, con tipo y tamaño validados.
5. **La empresa destino la determina el dominio**, no un dato del formulario. No se puede enviar una solicitud a una empresa distinta manipulando el envío.

El registro que se deja en la bitácora por este alta **no contiene datos personales**: solo el código del caso y el canal de entrada.

5. Protección de archivos: ningún archivo es público

El sistema almacena documentos, evidencias de consentimiento, adjuntos de incidentes y de solicitudes ARCO-P, fondos de certificado y certificados emitidos. **Ninguno es accesible por una URL pública.**

Cada descarga atraviesa tres comprobaciones:

```
# core/views/media_view.py
class ProtectedMediaView(APIView):
    permission_classes = [IsAuthenticated]          # 1. estar autenticado

    def get(self, request, schema, path):
        if schema != connection.schema_name:        # 2. el archivo es de SU empresa
            raise Http404()                         #    (404, no 403: no se revela que existe)

        required_perm = None
        for prefix, perm in MEDIA_PERMISSION_REGISTRY.items():
            if path.startswith(prefix):
                required_perm = perm
                break
        if required_perm is None:                   # 3. prefijo no registrado → DENEGADO
            raise PermissionDenied("No autorizado para acceder a este recurso.")

        if not (user.is_superuser or user.has_perm(required_perm)):
            raise PermissionDenied("No tiene permiso para acceder a este archivo.")
```

5.1 Registro de permisos por tipo de archivo

```
MEDIA_PERMISSION_REGISTRY = {
    "documents/":  "core.view_document",
    "consents/":   "core.view_consent",
    "incidents/":  "core.view_incident",
    "arcop/":      "core.view_arcorequest",
    "trainings/":  "core.view_training",
}
```

Denegación por omisión: un prefijo que no esté en esta lista **se rechaza**. Añadir un tipo nuevo de archivo sin registrar su permiso no lo deja accesible: lo deja inaccesible.

5.2 Cuatro medidas adicionales

- **Aislamiento físico por empresa.** Los archivos se guardan bajo una ruta que incluye el esquema de la empresa. Pedir el archivo de otra empresa devuelve **404**, no 403: no se confirma siquiera que exista.
- **Protección contra recorrido de rutas.** La ruta absoluta resultante se comprueba contra la raíz de almacenamiento; cualquier intento de salir de ella devuelve 404.
- **Validación en la subida.** Tipo y tamaño limitados. Límite general **10 MB**; las evidencias de consentimiento están además restringidas a **PDF y 5 MB**.
- **Almacenamiento nacional.** Los archivos residen **exclusivamente en servidores ubicados en Perú**. Es una decisión de cumplimiento (apartado 7.4).

6. Trazabilidad: la bitácora inmutable

6.1 Qué se registra

Cada empresa tiene su propia bitácora (`core_securitylog`), escrita **automáticamente** por todos los módulos. Doce tipos de evento:

Evento	Qué registra
`create` / `update` / `delete`	Alta, modificación y baja de cualquier registro de negocio.
`approve`	Aprobación formal de un documento.
`revoke`	Revocación de un consentimiento.
`notify`	Envío de la notificación de un incidente.
`login` / `logout` / `login_failed`	Acceso, cierre de sesión e **intento fallido**.
`export` / `import`	Descarga y carga de archivos Excel.
`permission_change`	Cambio de permisos.

Cada asiento guarda: usuario, **copia del nombre de usuario** (sobrevive a su borrado), acción, módulo, tipo e identificador del objeto, detalle en JSON, **dirección IP** y fecha y hora.

6.2 Inmutabilidad

La bitácora **solo admite inserciones**. Modificar o borrar un asiento está bloqueado:

```
def save(self, *args, **kwargs):
    if self.pk is not None:
        raise ValueError("SecurityLog es inmutable: no se permite modificar registros.")
    super().save(*args, **kwargs)

def delete(self, *args, **kwargs):
    raise ValueError("SecurityLog es inmutable: no se permite eliminar registros.")
```

No hay ninguna pantalla, punto de entrada de la API ni permiso que permita alterarla. **Ni siquiera el rol Administrador puede modificarla**: el único permiso relacionado es `view_securitylog`.

Las tres líneas de tiempo de módulo (`core_consenthistory`, `core_incidenthistory`, `core_arcohistory`) siguen la misma regla.

6.3 La bitácora nunca rompe la operación

```
def log_action(...):
    try:
        SecurityLog.objects.create(...)
    except Exception:
        logger.exception("No se pudo registrar la acción en la bitácora de seguridad.")
```

Si la escritura del asiento falla, **la operación de negocio continúa** y el fallo se anota en el registro técnico del servidor. Es una decisión consciente: un fallo al auditar no debe impedir que se registre un incidente de seguridad o se atienda a un ciudadano. La contrapartida —un fallo de la bitácora podría pasar inadvertido para el usuario— se acepta y se declara aquí.

6.4 La bitácora no contiene datos personales

Regla de diseño transversal: los modelos que contienen datos personales devuelven **solo su código** como representación textual, precisamente porque esa representación se vuelca en la bitácora.

```
def __str__(self):
    # Nunca nada más que el código: la bitácora vuelca esta representación.
    return self.risk_code or '(sin código)'
```

El campo `detail` guarda **los nombres de los campos modificados, nunca sus valores**. El único dato personal presente en la bitácora es el **nombre y correo del usuario interno que ejecutó la acción**, que es precisamente su finalidad.

6.5 Bitácora de plataforma

En el esquema `public`, `customer_platformlog` registra las acciones de los superadministradores de Gestitel: creación de empresas, emisión y suspensión de licencias, alta de superadministradores y **cada acceso a una empresa cliente**.

Registra también los cambios del **límite de documentos** de una empresa (`document_limit_updated`) y los de la **configuración del asistente** (apartado 3.3), con dos acciones separadas: `ai_key_updated` cuando se reemplaza la clave de acceso al proveedor, y `ai_settings_updated` cuando cambian el interruptor, el proveedor o el modelo. **El valor de la clave no se escribe nunca en la bitácora**: del primer evento queda solo quién y cuándo; del segundo, los nombres de los campos modificados.

7. Tratamiento de datos personales (ISO/IEC 27701 y Ley N.º 29733)

7.1 Dónde hay datos personales

Tabla	Datos personales que contiene	De quién
`core_consent`	Documento de identidad, nombre, correo, teléfono del titular.	**Terceros** (titulares).
`core_arcorequest`	Nombres, apellidos, tipo y número de documento, domicilio, distrito, provincia, departamento, teléfono, celular, correo — **del solicitante y de su representante**.	**Terceros** (ciudadanos).
`core_incident`	Datos del representante de la entidad, contacto del oficial de protección de datos, y **número de titulares y tipos de datos afectados**.	Personal interno y, de forma agregada, terceros.
`core_asset`	**Registro de actividades de tratamiento**: finalidad, categorías de datos, base legal, plazo de conservación, transferencias y flujos transfronterizos.	Descripción de tratamientos (no identifica personas).
`core_personaldataoperation`	Descripción del hecho, destinatario de una compartición/cesión, finalidad y motivo de anulación — texto libre que puede nombrar a terceros concretos (a quién se compartió, por qué).	**Terceros**, potencialmente. **Nunca se vuelca a `core_securitylog`** (apartado 6.4).

Tabla	Datos personales que contiene	De quién
`core_personaldataimpactassessment`	Análisis de necesidad/proporcionalidad y de los riesgos para los titulares — texto de análisis, no datos de identificación de una persona concreta.	Descripción de análisis (no identifica personas).
`core_trainingassignment`, `core_certificate`	Vínculo entre un empleado y su formación, sus puntajes y su certificado.	Personal interno.
`auth_user` de cada empresa	Nombre, apellidos, correo de los usuarios.	Personal interno.
`core_securitylog`	Nombre de usuario e IP de quien ejecutó cada acción.	Personal interno.

Los archivos adjuntos merecen mención aparte: **los adjuntos de una solicitud ARCO-P incluyen habitualmente copia del documento de identidad** del ciudadano y, en su caso, el poder de representación. Son de los datos más sensibles del sistema y están protegidos por el mecanismo del apartado 5.

7.2 Las cinco medidas aplicadas

1. La representación textual nunca expone datos personales (apartado 6.4).

2. Minimización en la bitácora: nombres de campos, nunca valores.

3. Historiales inmutables en Consentimientos, Incidentes y ARCO-P: la trazabilidad del tratamiento de los datos de un ciudadano no se puede alterar a posteriori.

4. Evidencia verificable: la evidencia de un consentimiento se guarda como PDF con su **resumen criptográfico SHA-256** calculado por el sistema, lo que permite demostrar que no fue alterada.

5. Advertencia previa a la exportación: los archivos Excel de Consentimientos, Incidentes, ARCO-P y participantes de Capacitaciones **contienen datos personales**. La interfaz lo advierte explícitamente antes de descargar, y la descarga queda registrada en la bitácora como evento `export`.

7.3 Derechos de los titulares

El módulo ARCO-P implementa el ejercicio de los derechos de Acceso, Rectificación, Cancelación, Oposición y Portabilidad conforme a la Ley N.º 29733:

- **Recepción por canal público** sin necesidad de ser usuario.
- **Plazo legal fotografiado** al recibir la solicitud: 20 días calendario para Acceso, 10 para los demás. Una vez fijado **no se recalcula**, aunque cambie la configuración.
- **Semáforo de vencimiento** derivado en cada consulta (a tiempo / por vencer / vencida).
- **Historial inmutable** de cada actuación sobre el caso.
- **La recepción sigue operativa aunque la licencia esté vencida** (apartado 3.1).

7.4 Localización de los datos

Decisión de cumplimiento vigente: el almacenamiento se realiza exclusivamente en servidores ubicados en Perú. No se emplean servicios de nube extranjeros para los datos ni para los documentos del SGSI. El objetivo es evitar transferencias internacionales de datos personales.

Excepción declarada. El sistema incorpora un asistente de consultas teóricas sobre normativa y gestión de seguridad que **envía la pregunta del usuario a un proveedor externo situado fuera de Perú** —el servicio intermediario **OpenRouter**, que a su vez la reenvía al fabricante del modelo configurado—. Sus límites:

- Responde **únicamente consultas teóricas**; no accede a ningún dato de la empresa, no consulta la base de datos y no ejecuta acciones.
- **No almacena nada**: ni la pregunta ni la respuesta se guardan en la base de datos, ni siquiera en la bitácora. La conversación existe solo en el navegador y desaparece al recargar.
- La interfaz advierte expresamente al usuario que **no introduzca datos personales**.
- Está gobernado por un interruptor que **viene desactivado de fábrica** y que solo puede encender el superadministrador de Gestitel (apartado 3.3). Con él apagado —o sin clave configurada—, la funcionalidad no aparece y el punto de entrada devuelve un error.
- Lo único que el sistema envía al proveedor es la pregunta escrita por el usuario, los últimos turnos de esa misma conversación y una instrucción fija de alcance. **Ningún dato de la empresa viaja con ella.**
- Límite de 30 consultas por hora y por usuario.

Se documenta como **riesgo aceptado y acotado**, no como omisión.

8. Seguridad del transporte y de la configuración

Medida	Estado
Redirección a HTTPS	Configurable por entorno. **Debe activarse en producción.**
Cookies marcadas como seguras	Configurable; activo por omisión fuera de modo depuración.
HSTS	Configurable; requiere certificado estable.
Cabecera de proxy para HTTPS	Configurada.
Orígenes de confianza para CSRF	Configurables por entorno.
Archivos servidos desde disco	Solo los estáticos de la aplicación. Los archivos de usuario **nunca** (apartado 5).
Credenciales	En variables de entorno. **No figuran en el repositorio de código.**
Clave de acceso al proveedor del asistente	**Única credencial que se guarda en la base de datos**, y se guarda **cifrada** (cifrado simétrico autenticado, `customer_platformaisettings.api_key_encrypted`). La **clave maestra** que la descifra está en una variable de entorno del servidor, distinta en cada entorno, y **no** en la base ni en el repositorio: una copia de la base de datos, por sí sola, no permite recuperar la clave. Perder o cambiar la clave maestra obliga a volver a introducir la clave del proveedor.
Dominios	**No están escritos en el código**; se configuran por entorno.

Nota sobre el entorno de pruebas (QA). El entorno de validación opera sobre **HTTPS**, con certificados de Let's Encrypt emitidos por nombre de dominio y renovación automática, redirección de HTTP a HTTPS y cookies marcadas como seguras. Cada empresa nueva requiere ampliar el certificado con su subdominio (documento 06, Parte A).

8.1 La aplicación web: qué controla y qué no

La aplicación web (repositorio `frontend_gestitel`) **no es una barrera de seguridad**: la autoridad sobre lo que cada usuario puede ver o hacer la ejerce siempre el servidor. Lo que hace la aplicación es acompañar esos controles en la experiencia del usuario:

Aspecto	Comportamiento
Permisos en pantalla	Los botones y pestañas se ocultan según los permisos del rol. Es una ayuda de usabilidad: si se intenta una acción sin permiso, el servidor responde `403` y la aplicación muestra el aviso «No tiene permiso para esta acción».
Sesión	El inicio de sesión se valida siempre contra la API. El token de acceso y el de renovación se guardan en el almacenamiento local del navegador, con claves separadas por empresa (subdominio), y el token de acceso se renueva automáticamente al vencer.
Licencia	Ante un `403` con código `LICENSE_EXPIRED` o `SERVICE_SUSPENDED`, la aplicación muestra una pantalla de bloqueo con el motivo, distinta del aviso de permiso.
Cambio de contraseña obligatorio	Si el perfil lo exige, la aplicación obliga a cambiar la contraseña antes de continuar.
Comunicación con el servidor	Un único cliente HTTP central concentra la inyección del token, su renovación y el tratamiento de errores; ninguna pantalla se comunica con el servidor por su cuenta.
Ruta pública	La única pantalla accesible sin iniciar sesión es el formulario de derechos ARCO-P (`/derechos-arcop`), que solo envía solicitudes.
Mismo origen	La aplicación y la API se sirven desde el mismo dominio de la empresa, por lo que no se exponen orígenes cruzados.
Credenciales	La aplicación no contiene usuarios, contraseñas ni tokens incrustados, y nunca guarda la contraseña del usuario.

9. Limitaciones conocidas y supuestos

Este apartado existe porque un documento de seguridad que no declare sus límites no es auditable. Ninguno de estos puntos es un defecto oculto: son **decisiones con contrapartida conocida**.

1. Las reglas de negocio se aplican en la aplicación, no en el motor. Quien tenga acceso directo a PostgreSQL con privilegios de escritura puede saltarse las validaciones, los cálculos automáticos, la inmutabilidad de la bitácora y el borrado lógico. Lo único que el motor garantiza siempre son las restricciones declarativas (llaves, unicidad, no-nulidad). **Medida complementaria requerida:** restringir y registrar el acceso directo a la base de datos; es un control de sistema operativo y de permisos de PostgreSQL, no de la aplicación. Ver documento **04**, apartados 1.3 y 4.

2. El personal de Gestitel puede acceder a los datos de cualquier empresa cliente. Es inherente al modelo de servicio administrado. Está registrado en la bitácora de plataforma y debe reflejarse en el contrato de encargo de tratamiento.

3. El borrado es lógico: los datos no se destruyen. Eliminar un registro lo oculta, pero la fila permanece. **Implicación para el derecho de cancelación:** atender una solicitud de supresión de datos personales que exija destrucción efectiva requiere una intervención técnica adicional; la eliminación desde la interfaz no la produce por sí sola.

4. Un fallo de la bitácora pasa inadvertido para el usuario (apartado 6.3). **Medida complementaria recomendada:** vigilar el registro técnico del servidor.

5. La actualización de roles es aditiva. `populate_roles.py` concede permisos pero no revoca. Un rol al que se le retiró manualmente un permiso puede recuperarlo al instalar una versión que lo incluya en la plantilla. **Medida recomendada:** revisar la matriz de permisos tras cada actualización.

6. Solo el rol «Administrador» está marcado como de sistema. «Editor» y «Lector» pueden renombrarse o eliminarse desde la interfaz.

7. El formulario público no tiene CAPTCHA. La protección frente a envíos masivos es el límite de 10 peticiones por minuto. **Medida recomendada** si se observa abuso: añadir una verificación adicional.

8. La sesión dura 8 horas. Es un compromiso entre seguridad y usabilidad. No hay cierre de sesión por inactividad.

9. No hay segundo factor de autenticación. El acceso se basa en usuario y contraseña.

10. El asistente de consultas teóricas envía la pregunta a un proveedor externo fuera de Perú (apartado 7.4), con el alcance y los límites allí descritos. Viene desactivado de fábrica. El envío pasa por un **intermediario** (OpenRouter) que lo reenvía al fabricante del modelo elegido: son **dos** terceros en la cadena, no uno, y el segundo depende del modelo que el superadministrador tenga configurado en cada momento.

11. La protección de la clave del asistente depende de la custodia de la clave maestra. El cifrado impide leer la clave del proveedor desde una copia de la base de datos, pero quien tenga a la vez acceso a la base **y** a las variables de entorno del servidor puede descifrarla. Es el límite inherente a cualquier cifrado con la clave en el mismo servidor.

12. Los tokens de sesión se guardan en el almacenamiento local del navegador. Es un patrón habitual en aplicaciones de una sola página, pero un fallo de inyección de código en el navegador (XSS) podría leerlos. **Medida recomendada:** mantener la política de no incrustar contenido de terceros en la aplicación y evaluar, a futuro, el uso de cookies `httpOnly` para el token de renovación.

Resumen ejecutivo

Pregunta	Respuesta
¿Puede una empresa ver datos de otra?	No. Los datos viven en esquemas PostgreSQL separados, sin llaves foráneas entre ellos, y el token de sesión está atado a un esquema concreto.
¿Puede un usuario ver un módulo sin permiso?	No. Ver exige `view_<entidad>`, incluso para consultar.
¿Puede alguien alterar la bitácora?	No desde la aplicación: es inmutable por diseño y ningún permiso lo habilita. Sí con acceso directo a la base de datos (limitación 1).
¿Hay archivos accesibles públicamente?	No. Toda descarga exige autenticación, pertenencia a la empresa y permiso sobre ese tipo de archivo; lo no registrado se deniega.
¿Hay algún punto sin autenticación?	Uno: el formulario público de derechos ARCO-P. Solo crea, con límite de peticiones y sin capacidad de leer nada.
¿Dónde se almacenan los datos?	Exclusivamente en servidores en Perú, con la excepción declarada y acotada del asistente de consultas teóricas.
¿Qué pasa si vence la licencia?	Se bloquea el acceso de los usuarios de la empresa, salvo la recepción de solicitudes de derechos de ciudadanos, que continúa por obligación legal.

Documentos relacionados

Documento	Contenido
01 — Diagramas entidad-relación	Mapa visual por dominio funcional.
02 — Diccionario de datos	Las 52 tablas columna por columna, con marca de los campos con datos personales.

Documento	Contenido
03 — Esquema de la base de datos	Llaves, restricciones e índices.
04 — Procedimientos SQL y scripts	Dónde vive la lógica de negocio y qué garantiza el motor.